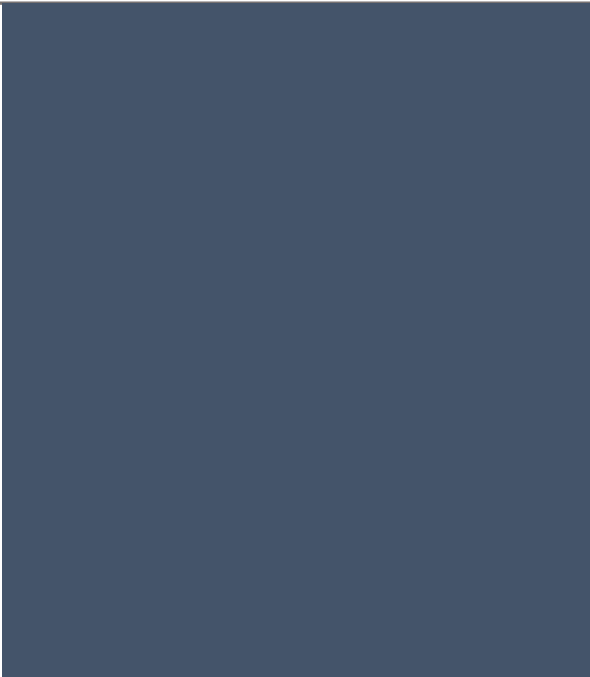




Glosario - CIB

ÁLVARO ALLÉN PERLINES

Contenido

Amenazas y vulnerabilidades.....	3
Amenazas.....	3
Cifrar.....	3
Confidencialidad	3
Cross-Site Scripting(XSS).....	3
DDoS.....	4
Disponibilidad	4
DoS	5
Exploits.....	5
Ingeniería social.....	5
Integridad.....	5
Inyección SQL.....	5
Malware	6
Man-in-the-Middle	6
Ransomware	6
Vulnerabilidad	6
Medidas de protección básicas	7
Autenticación “multifactor” (MFA).....	7
Roles.....	7
Permisos.....	7
Reglas	8
Firewall.....	8
Filtrado	8
Puertas	9
Protocolos	9
Routers.....	9
Monitoreo	10
Auditoría	10
Análisis de los incidentes de seguridad	11
Incidentes de seguridad	11
Ciclo de vida de un incidente	11
Detección	11
Análisis	11
Contención.....	11
Erradicación	11

Recuperación	11
Aprendizaje	11
Indicadores de compromiso (IoC)	11
Estrategias proactivas.....	11
Análisis forense.....	11
Herramientas y tecnologías de aplicación	11
Cortafuegos.....	11
IDS/IPS	11
Antivirus.....	11
Cortafuegos basados en red.....	11
Cortafuegos basados en host	11
IDS	11
IPS.....	11
Antimalware	11
Normativa y buenas prácticas de uso	12
Reglamento general de Protección de Datos (RGPD)	12
ISO/IEC 27001	12
Esquema Nacional de Seguridad (ENS)	12
Datos sensibles	12
Políticas de acceso	12
Ciclo de vida de la información	12
Diagnóstico de fallos	12
Propuesta de mejora	12
Registro de incidencias.....	12

Amenazas y vulnerabilidades

Amenazas

Se refiere a cualquier tipo de peligro o riesgo que pueda surgir a través de la red o de dispositivos conectados a Internet. Estas amenazas pueden incluir virus informáticos, [malware](#), phishing, ataques [DoS](#), robo de datos, etc...

Bibliografía:

- [Qué significa amenaza cibernética - Intelligent Protection](#)

Cifrar

Según la RAE, cifrar es “transcribir en guarismos¹, letras o símbolos, de acuerdo con una clave, un mensaje o texto cuyo contenido se quiere proteger”. En términos más informáticos es el proceso de transformar texto legible sin formato en texto cifrado ilegible para enmascarar información confidencial de usuarios no autorizados. Esta práctica es realizada por las empresas cuando quieren proteger información sensible como modelos, pruebas, resultados o cualquier otra cosa que pueda ser usada en su contra.

Bibliografía:

- [¿Qué es el cifrado? | IBM](#)

Confidencialidad

Se trata de una propiedad de la información que pretende garantizar el acceso sólo a las personas autorizadas. Los responsables de dicha información deciden quien tiene derecho a acceder a la misma. La característica principal de la confidencialidad es la no divulgación de un contenido.

Bibliografía:

- [Confidencialidad - Qué es, definición y concepto](#)

Cross-Site Scripting(XSS)

Es una vulnerabilidad de seguridad que permite a los atacantes inyectar scripts maliciosos en páginas web confiables. Estos scripts, normalmente en JS, se ejecutan en

¹ Guarismos: signos y cifras arábigas que representan cantidades numéricas del 0 al 9.

el navegador de los usuarios, comprometiendo su información personal, cookies de sesión o incluso redirigiéndose a sitios maliciosos.

Hay diferentes tipos de XSS:

- **Reflected XSS (no persistente):** el script se inyecta a través de entradas de usuario, como formularios o parámetros, y se disuelve directamente en la respuesta del servidor sin ser almacenado.
- **Stored XSS (persistente):** el script se almacena en el servidor, como en bases de datos o campos de comentarios. Cada vez que un usuario carga la página afectada, el script se ejecuta automáticamente, afectando a múltiples usuarios.
- **DOM-Based XSS:** el script malicioso se inyecta directamente en el DOM² del navegador, sin pasar por el servidor. Esto ocurre cuando el código JS manipula entradas no validadas, como “document.write(location.hash)”

Bibliografía:

- [XSS \(Cross-Site Scripting\): ¿Qué es? ¿Cómo protegerse de esto?](#)
- [Cross Site Scripting \(XSS\) | OWASP Foundation](#) (traducida con IA)

DDoS

Un ataque de Denegación de Servicio Distribuido (Distributed Denial of Service) es igual que un ataque [DoS](#) en su esencia, denegar el servicio de una web, pero usando varios dispositivos para dificultar la situación. La teoría es la siguiente: un servidor realiza ataques a dispositivos de IT (Internet of Things) que tienen un software muy pobre en temas de seguridad. Intenta conectarse mediante usuarios y contraseñas creadas de fábrica y usando la fuerza bruta. Una vez conectado el servidor guarda el usuario y la contraseña junto con la IP y le inyecta un malware en la RAM para que sea indetectable. Este [malware](#) es el que más tarde va a usarse para realizar el ataque. Cuando la red de dispositivos es de un tamaño considerable se realiza el ataque, en vez desde una IP, desde tantas como dispositivos haya infectados. En estos casos, es más complicado solucionar el ataque.

Disponibilidad

La disponibilidad en ciberseguridad se refiere a la capacidad de acceder y utilizar información y sistemas informáticos cuando se necesitan. Es un principio fundamental de la seguridad informática que asegura la fiabilidad y el acceso oportuno a los datos por parte de individuos autorizados.

² DOM (Modelo de Objetos del Documento): interfaz de programación que representa la estructura de un documento HTML o XML en la memoria.

DoS

Un ataque de Denegación de Servicio (Denial of Service) es un ataque cibernético en el que se deniega el acceso a un servidor web mediante la petición masiva por parte de un dispositivo. Éste realiza una cantidad enorme de peticiones al servidor, el servidor intenta responder a todas sus peticiones usando todos sus recursos y se queda sin espacio para el resto de peticiones denegando el servicio a los clientes reales.

Para solucionar este problema, la empresa deberá denegar el acceso a la IP del ordenador atacante. Por tanto este tipo de ataque no suele hacer daño alguno.

Exploits

Es un software de ataque que aprovecha las vulnerabilidades de las aplicaciones, las redes, los sistemas operativos o el hardware. Los exploits toman la forma de un programa de software o una secuencia de código previsto para hacerse con el control de los ordenadores o robar datos de red.

Bibliografía:

- [¿Qué es un exploit de ordenador? Definición de exploit](#)

Ingeniería social

Es un conjunto de prácticas y técnicas utilizadas para manipular y engañar a las personas con el fin de obtener información confidencial o hacer que realicen acciones no deseadas. Estos ataques pueden llevar a que las víctimas compartan datos sensibles, descarguen software malicioso o realicen transacciones financieras a favor de los delinquentes. La esencia está en la explotación de la psicología humana en vez de la técnica de hacking.

Bibliografía: [ingenieria social definicion - Búsqueda](#)

Integridad

Es un valor de quien tiene entereza moral, rectitud y honradez en la conducta y en el comportamiento. Esta integridad se puede referir a un individuo educado, honesto, que tiene control emocional, que tiene respeto por sí mismo. También responsable, disciplinario, directo, puntual, leal, pulcro y que tiene firmeza en sus acciones.

Inyección SQL

Es la inyección de sentencias SQL usando vulnerabilidades de la página web como el apartado de inicio de sesión. Con la introducción de "id=1" || ""="" puedes recibir toda la información de la tabla usuarios incluido nombre, correo, contraseña (debería estar cifrada), etc...

Bibliografía:

- [Inyección de Código](#)

Malware

Es un programa o código malicioso que es dañino para los sistemas. Este malware busca invadir, dañar o deshabilitar computadoras, sistemas informáticos, redes, tabletas y dispositivos móviles, a menudo controlando parcialmente las operaciones de un dispositivo.

Los usuarios que desarrollan estos códigos buscan ganar dinero, sabotear tu capacidad de trabajar, hacer una declaración política o, la peor de todas, por simple aburrimiento y chulería.

Bibliografía:

- [¿Qué es el Malware? Definición de Malware, Tipos y Protección](#)

Man-in-the-Middle

Es un tipo de ciberataque en el que alguien intercepta la comunicación entre dos dispositivos conectados en la red. Alguien se pone en el medio sin permiso para interceptarla y hacer con ella lo que quiera. También pueden reenviarte a una página web que no has solicitado y robarte la información que introduzcas en ella. La forma de conseguir interceptar la comunicación es averiguando la IP y la MAC del dispositivo al que quieres suplantar e intercambiar ambas direcciones para que el emisor del mensaje lo mande al atacante.

Bibliografía: [Ataque Man-in-the-Middle: qué es, cómo funciona y cómo protegerte de él](#)

Ransomware

Es un tipo de malware que ataca de manera indiscriminada a dispositivos conectados en al red. El ataque consiste en cifrar todos los archivos de un dispositivo y pedir una transferencia de bitcoin a una cartera del Blockchain³ para conservar el anonimato. El malware puede llegar desde una descarga de contenido pirata, el correo de un jefe o, incluso, en las macros de un Word el cual muestra un mensaje falso.

Vulnerabilidad

Es el riesgo que una persona, sistema u objeto puede sufrir frente a peligros inminentes. En términos de ciberseguridad, las amenazas que existen frente a un sistema informático, aprovechan estas vulnerabilidades para cometer actos ilegales, ataques o robos, entre otras.

³ Blockchain: es un tipo de base de datos parecido a un libro de contabilidad digital, descentralizado y mantenido por una red distribuida de computadoras.

Bibliografía:

- [Vulnerabilidad: qué es, tipos y ejemplos - Enciclopedia Significados](#)

Medidas de protección básicas

Autenticación “multifactor” (MFA)

Es un método de seguridad que requiere dos formas de identificación para acceder a recursos y datos. Normalmente, el primer factor es una contraseña y el segundo puede ser desde un mensaje SMS al teléfono indicado o pulsar en un dialogo emergente desde el dispositivo conectado. A día de hoy es muy común el uso de métodos biométricos como huellas dactilares y reconocimiento facial.

Bibliografía:

- [¿Qué es y cómo se usa el Doble Factor de Autenticación \(2FA\)? | Prometeo](#)

Roles

En un sistema operativo, los roles son colecciones de permisos que se definen para un sistema específico y pueden ser asignados a usuarios en contextos particulares. En resumen, determinan las habilidades y niveles de acceso que un usuario tiene dentro del sistema, lo que es fundamental para la gestión de la seguridad y el control de acceso. Ejemplos de roles son administrador como jefe total de la aplicación, usuario identificado que se le atribuye los clientes y usuario no identificado que es aquel que se ha conectado al servidor pero no ha iniciado sesión. Éstos últimos suelen ser los que menos privilegios albergan. Dependiendo de que rol tengas podrás acceder a unos lugares u otros, incluso puede que la interfaz de la aplicación sea diferente.

Bibliografía:

- [Roles En Informática: Definición, Importancia Y Ejemplos - ServerNet](#)

Permisos

Los permisos informáticos son el conjunto de autorizaciones que se otorgan a un usuario o sistema para interactuar con un recurso específico. Estos permisos determinan que acciones pueden realizarse sobre el recurso, como leer, modificar, eliminar o ejecutar. La gestión de estos permisos y analizar a que usuarios deben darse es fundamental para proteger la información y los recursos. Los tipos de permisos más comunes son:

- **Lectura:** permite visualizar el contenido de un recurso sin modificarlo.
- **Escritura:** permite modificar el contenido de un recurso.
- **Ejecución:** permite ejecutar archivos o programas.

- **Eliminación:** permite borrar el recurso.
- **Permisos especiales:** como cambiar la configuración de seguridad o delegar permisos a otros usuarios.

Es importante recalcar que estos permisos están muy relacionados con los [roles](#) que un usuario tiene. Dependiendo del rol que ostenta tiene ciertos permisos.

Bibliografía:

- [Definición de Permisos de acceso \(informática\)](#)

Reglas

En informática, una regla se define como un conjunto de instrucciones o procedimientos que establecen los límites y condiciones bajo los cuales se debe desarrollar, implementar y mantener un sistema o aplicación. En programación, las reglas son directrices que se deben seguir al escribir código, definiendo la sintaxis y la estructura correcta que debe tener un programa para que sea válido y funcione correctamente.

Bibliografía:

- [Definición de Regla en Informática según Autor, ejemplos, qué es, Concepto y Significado](#)

Firewall

Es un sistema de seguridad de red que restringe el tráfico de Internet entrante y saliente o dentro de una red privada. Funciona bloqueando o permitiendo paquetes de datos de forma selectiva, protegiendo así a las computadoras o redes de accesos no autorizados. Además, supervisan y controlan el tráfico de la red según un conjunto de reglas de seguridad, situándose entre una red de confianza y una red no fiable, como Internet.

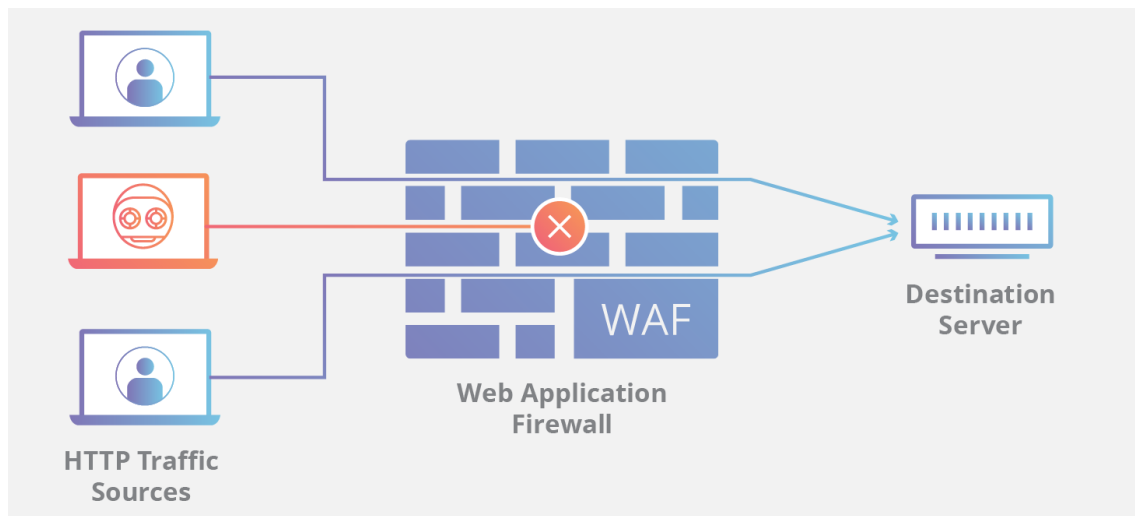
Bibliografía:

- [¿Qué es un firewall? Funcionamiento de los firewalls y tipos de firewalls](#)

Filtrado

Cuando hablamos de filtrado en el desarrollo web nos referimos a la medida de seguridad que controla y restringe el acceso a sitios web específicos para proteger a los usuarios de amenazas en línea. Su objetivo es bloquear sitios web maliciosos,

inapropiados o no relacionados con el trabajo, garantizando un entorno seguro y productivo.



Bibliografía:

- [Implementación Control A.8.23 – Filtrado web - InfoProtección](#)

Puertas

Protocolos

Los protocolos de ciberseguridad son conjuntos de reglas y normas que se establecen para proteger la información y los sistemas informáticos de posibles amenazas y ataques cibernéticos. Estos protocolos garantizan la [confidencialidad](#), [integridad](#), [disponibilidad](#) de los datos, así como la prevención del acceso no autorizado a la red y a los dispositivos. Incluyen medidas como el [cifrado de datos](#), la [autenticación de usuarios](#), la implementación de [firewalls](#) y la realización de copias de seguridad periódicas.

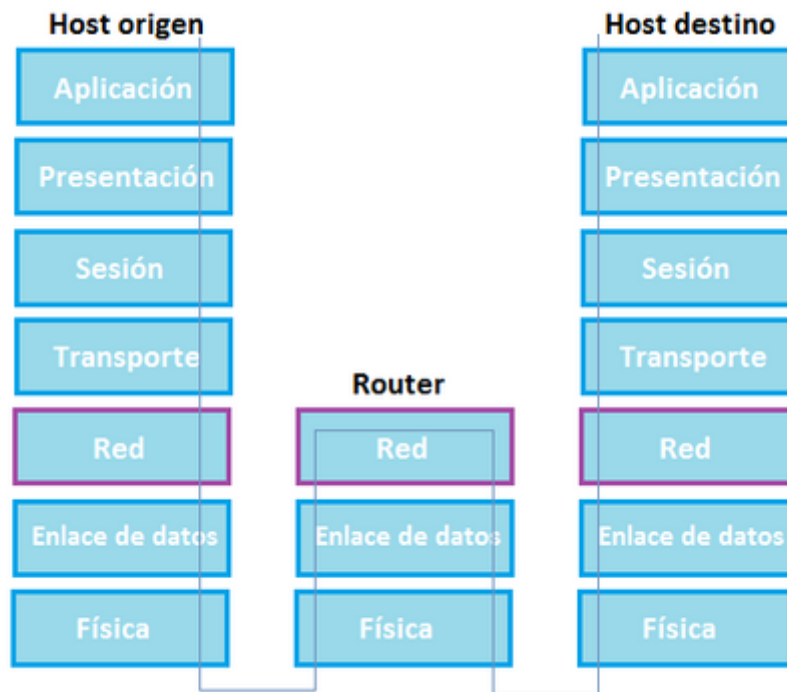
Bibliografía:

- [Qué son los protocolos de ciberseguridad - Intelligent Protection](#)

Routers

Es un dispositivo que permite interconectar redes con distinto prefijo en su dirección IP. Su función es la de establecer la mejor ruta que destinará a cada paquete de datos para llegar a la red y al dispositivo de destino. Es bastante utilizado para conectarse a Internet, ya que se conecta la red de nuestro hogar, oficina o cualquier red a la red de nuestro proveedor de este servicio. La mayoría de los rúteres que se utilizan para el

hogar y oficinas tienen incorporadas otras funciones adicionales al enrutador, como el punto de acceso inalámbrico, el módem que convierte las señales analógicas en digitales y viceversa o el conmutador que conecta varios dispositivos a través de cable, creando una red local.



Bibliografía:

- [Rúter - Wikipedia, la enciclopedia libre](#)

Monitoreo

El monitoreo de ciberseguridad es un proceso sistemático y continuo que permite a las organizaciones observar y analizar los activos digitales para detectar y responder a posibles amenazas. Este proceso implica la recopilación de datos en tiempo real, lo que permite identificar brechas de seguridad, vulnerabilidades y actividades sospechosas antes de que causen daños significativos. Además, ayuda a garantizar la fiabilidad y estabilidad de los sistemas, asegurando que las operaciones empresariales y la integridad de la información estén protegidas.

Bibliografía:

- [La importancia del monitoreo y análisis de ciberseguridad - Network Security Alliance](#)

Auditoría

Una auditoría de ciberseguridad es un proceso esencial que evalúa la postura de seguridad de una organización. Este proceso incluye diversas actividades destinadas a identificar debilidades y riesgos en el ámbito cibernético, así como a establecer medidas

para mitigar dichas amenazas. Se trata de una evaluación exhaustiva de los sistemas, políticas y prácticas de una organización para asegurar que se cumplen los estándares de seguridad.

Bibliografía:

- [¿Qué es una Auditoría de Ciberseguridad? - APPbera.com](https://www.appbera.com/que-es-una-auditoria-de-ciberseguridad/)

Análisis de los incidentes de seguridad

Incidentes de seguridad

Ciclo de vida de un incidente

Detección

Análisis

Contención

Erradicación

Recuperación

Aprendizaje

Indicadores de compromiso (IoC)

Estrategias proactivas

Análisis forense

Herramientas y tecnologías de aplicación

Cortafuegos

IDS/IPS

Antivirus

Cortafuegos basados en red

Cortafuegos basados en host

IDS

IPS

Antimalware

Normativa y buenas prácticas de uso

Reglamento general de Protección de Datos (RGPD)

ISO/IEC 27001

Esquema Nacional de Seguridad (ENS)

Datos sensibles

Políticas de acceso

Ciclo de vida de la información

Diagnóstico de fallos

Propuesta de mejora

Registro de incidencias